# slop-deps v1.4.0 — Full Audit Report

**Scope:** CLI (`src/`, `bin/`, `action.yml`, `.github/`, `test/`) + Site (`site/morpho/`) + vendored scanner drift **Method:** Static code review + 57-test suite run + **live reproduction against real registries** (npm, PyPI) **Overall:** CLI is genuinely solid — 57/57 tests pass, zero-dep claim is true, no secrets leaked. The SITE has one critical trust-killing bug and two structural divergence problems. CI is silently dead.

---

## ✅ What's fixed since last review (credit where due)

| Last review issue | Status |
|---|---|
| Title "Morpho Particle Field" / template OG | ✅ Fixed — proper title, OG, twitter card, favicon (site/morpho/index.html) |
| 1 MB github-octocat.png | ✅ Fixed — now 128×128 / 14 KB |
| Intro hardcoded timers, no readiness gate | ✅ Fixed — `fonts.ready + window load + first frame` gates (SlopDepsCanvas.tsx:442-554), intro loops until ready |
| No skip / no reduced-motion | ✅ Fixed — pointerdown/keydown skip, sessionStorage persistence, `prefers-reduced-motion` respected everywhere |
| No keyboard access on drop zone | ✅ Fixed — role=button, tabIndex, Enter/Space handler (SlopDropBox.tsx:730-738) |
| Dashboard XSS | ✅ Verified safe — `escapeHtml()` on all fields (web/dashboard.html:170-174,183) |
| Secrets in bundle | ✅ None found (grepped src + dist for keys/tokens — only env var names and a corpus package named `sk-sqlalchemy`) |

---

# 🔴 CRITICAL

## C1. Site flags stdlib imports as HALLUCINATED — every normal file red-flags

**File:** `site/morpho/src/utils/fileInspector.ts:523-589` **Also shipped in:** `site/morpho/dist/assets/index-DIv7WJsA.js` (deployed bundle contains the bug)

`isBuiltin()` is computed (line 524) but **never gates the registry check**. Node `node:` imports and Python stdlib imports go straight to the registry:

- `import fs from 'node:fs'` → `registry.npmjs.org/node%3Afs` → **404 guaranteed** (`:` is illegal in npm package names, so this can NEVER exist) → red **HALLUCINATED**
- `import os / sys / json` → `pypi.org/pypi/os/json` → **404** (verified live) → red **HALLUCINATED**

**Reproduced against the real registries** (not mocked):

```
=== app.js (REAL registries) ===
HALLUCINATED  node:fs      builtin module not on registry (404)
HALLUCINATED  node:path    builtin module not on registry (404)
VERIFIED      express      public registry verified

=== app.py (REAL registries) ===
HALLUCINATED  os           builtin module not on registry (404)
HALLUCINATED  sys          builtin module not on registry (404)
HALLUCINATED  json         builtin module not on registry (404)
VERIFIED      requests     public registry verified
```

The code even has the string `"builtin module not on registry (404)"` — someone saw this case and still returned HALLUCINATED. A visitor drops any real modern JS or Python file → instant red "AI hallucination trap!" alerts on `node:fs` and `import os`. Trust dies in 10 seconds. This is the single most damaging bug on the site.

**Fix (small):** in `inspectDroppedFileAsync`, right after the builtin check:

```
if (isBuiltin(pkgName, pkgEco)) {
  return { name: pkgName, version: dep.version, ecosystem: pkgEco,
           verdict: 'VERIFIED', isBuiltin: true, registryChecked:
         true,
           reason: 'standard library module' };
}
```

Optionally add a `node:` prefix early-return inside `checkPackageInRegistry` as defense-in-depth. Rebuild dist after the fix.

**Owner: AI Studio**

---

# 🟠 HIGH

## H1. Same input, opposite verdicts: site SUSPICIOUS vs CLI CLEAN (proven)

**Files:** `site/morpho/src/utils/fileInspector.ts:532-543` + `site/morpho/src/vendor/slop-deps/typosquat.js:76-117`

The vendored typosquat engine has no severity/age gating — ANY name within 1-2 edits of a corpus entry → **SUSPICIOUS** on the site. The CLI gates by package age (`src/typosquat.js:230-234`: established ≥365d → `suggestion` → **VERIFIED** with a caution note).

**Reproduced live with `loadsh`** (a real, published npm package):

```
CLI:   status=VERIFIED  risk=CLEAN   "Legitimate package, but the name closely resembles 'lodash'..."
SITE:  verdict=SUSPICIOUS            "resembles lodash"  (red row, claw mark)
```

Same for `koa2`: CLI clean, site red.

Anyone who scans on the site and then runs the CLI gets contradictory answers — that's fatal for a tool whose entire value proposition is verdict trust.

**Fix:** mirror CLI semantics. Cheapest correct version: since the site already fetches the registry when a typosquat match fires, don't early-return SUSPICIOUS at line 532-543 — keep the match, do the registry check, and if the package exists AND the registry data shows an established package, downgrade to VERIFIED with `reason: "closely resembles '<target>' — verify this import was intentional"`. Keep SUSPICIOUS only for: not-found, or young+few-versions (if you port that heuristic).

**Owner: AI Studio**

## H2. Vendored corpus is 6.6% of the CLI corpus — site misses typosquats the CLI catches

**Files:** `site/morpho/src/vendor/slop-deps/corpus.generated.js` vs `src/corpus.generated.js`

Measured: CLI npm **3,056** / pypi **1,021** / cargo **102** entries vs site npm **122** / pypi **85** / crates **69**. The vendor copy is a hand-rewritten file, not a generated sync — it also diverges in structure (inline arrays vs generated merge), and `vendor/builtins.js` is missing newer Node builtins (`sqlite`, `sea`, `sidecar_sdk`, `fs/promises`, …) that CLI has.

A typosquat of any mid-tier popular package (in the CLI's 3,056, not in the site's 122) sails through the site as VERIFIED.

**Fix:** stop hand-maintaining the vendor copy. Add a sync script (Node, run before `vite build`): import CLI's `src/typosquat.js` + `src/corpus.generated.js` + `src/builtins.js` + `src/pypi-map.js`, serialize them into `site/morpho/src/vendor/slop-deps/*.js` as pure-ESM data modules. One source of truth. A drift test asserting the generated files match a fresh sync would be ideal.

**Owner: AI Studio** (script lives in site; Antigravity exports/maintains the CLI corpus API)

## H3. CI is silently dead — corrupted branch filter

**File:** `.github/workflows/ci.yml:4,7`

```
branches: ain]      # ← literally "ain]" — no such branch exists
```

The workflow name ("Supply Chain Sentinel") runs **zero times** — your 57-test suite and the dogfood step have never executed on push. Classic mangled edit (`[main]` → `ain]`).

**Fix:**

```yaml
on:
  push:
    branches: [main]
  pull_request:
    branches: [main]
```

Then check the Actions tab — you'll likely see the workflow has never run.

**Owner: Antigravity**

### H4. action.yml loses the SARIF artifact exactly when findings exist

**File:** `action.yml` (Run slop-deps scan step + Upload step)

GitHub runs steps with `bash -e`. When the scan finds criticals it exits **1** → step fails → the upload-artifact step (no `if: always()`) is skipped. So the SARIF file is produced precisely when you'd want it, and thrown away. Also `slop-deps@1.4.0` + `package.json` version + `bin/slop-deps.js:11` VERSION = triple manual version sync (drift waiting to happen).

**Fix:**

```
- name: Run slop-deps scan
  shell: bash
  run: |
    set +e
    set -- npx --yes slop-deps@1.4.0 --dir "$SLOP_DEPS_DIRECTORY"
    [ "$SLOP_DEPS_STRICT" = "true" ] && set -- "$@" --strict
    if [ "$SLOP_DEPS_SARIF" = "true" ]; then
      "$@" --sarif > slop-deps.sarif
    else
      "$@"
    fi
    code=$?
    echo "SCAN_EXIT=$code" >> "$GITHUB_OUTPUT" || true
    exit $code
- name: Upload SARIF artifact
  if: ${{ always() && inputs.sarif == 'true' }}
  uses: actions/upload-artifact@<sha>   # pin to full commit SHA
```

(Or simpler: `continue-on-error: true` on the scan step + a final exit-code check step.)

**Owner: Antigravity**

---

# 🟡 MEDIUM

### M1. og:image / twitter:image are relative URLs

**File:** `site/morpho/index.html:22,35` — `content="/og-image.png"`. Twitter/X, LinkedIn, Slack and most scrapers require **absolute** URLs; link previews will render without the image. Fix after the domain is live: `https://yourdomain.tld/og-image.png`. **Owner: AI Studio**

## M2. Dashboard server: no Host-header validation (DNS-rebinding window)

**File:** `src/server.js:17-69` — Binds 127.0.0.1 ✓ and blocks path traversal ✓, but any page reached via DNS rebinding (attacker domain → 127.0.0.1) can read `/api/scan` responses and trigger scans, because the Host header is never checked. Fix: reject requests whose `Host` isn't `127.0.0.1:<port>` / `localhost:<port>`, or require a random token in the path. **Owner: Antigravity**

## M3. No file-size cap on drop

**File:** `site/morpho/src/components/SlopDropBox.tsx:420` (`processNativeFiles`) — `file.text()` loads the whole file into memory. A 200 MB log dropped by accident freezes/OOMs the tab — on a site whose pitch is "drop your file here." Fix: `if (file.size > 2_000_000) → error card "file too large (2 MB max)"`. **Owner: AI Studio**

## M4. Per-file concurrency pools stack

**File:** `site/morpho/src/utils/fileInspector.ts:68,476` — concurrency 6 is **per file**; dropping 10 files fires up to ~60 parallel registry requests → npm rate-limits (429) → mass `offline_error` → sea of UNCHECKED. Fix: one shared pool for the whole batch (lift `mapWithConcurrency` to accept a flattened package list), or global semaphore around `checkPackageInRegistry`. **Owner: AI Studio**

## M5. 8s timeout swallows real results, papers already shown

**File:** `site/morpho/src/components/SlopDropBox.tsx:384-417` — after the timeout resolves `error:'invalid'`, streamed papers already visible contradict the "INVALID MANIFEST" headline. Fix: on late resolution, replace the stub result (add an `applyLateResult`), or label the state "scan timed out — N packages checked". **Owner: AI Studio**

## M6. `isInsideJsxOrBlock` is O(n×m) — pathological on big/minified files

**File:** `src/extractors/js-ts.js:199-310` — called per match, rescans from offset 0 each time; plus `masked.slice(0, match.index+1).split('\n')` at line 355 allocates per match. Thousands of `require(` hits in a minified bundle → seconds-to-minutes CPU. Fix: precompute prefix brace-depth array + line-

start offsets once per file. (This is why you also shouldn't scan `dist/` output by hand — but the fix makes it safe anyway.) **Owner: Antigravity**

### M7. Spec–code mismatch is still open

**File:** `site/STORYBOARD_SPEC.md` — spec locks: wormhole camera dive into "1", double-outline SLOP DEPS letters, "GPU instancing". Code ships: radial burst, solid-fill lattice, 2D canvas sprites (SlopDepsCanvas.tsx:667-675). Either implement the dive (it's your signature move) or update the spec — a spec that lies erodes agent discipline. **Owner: Vidit decides, AI Studio implements**

### M8. Site says "alpha", CLI is v1.4.0

**File:** `site/morpho/src/components/TopPixelBar.tsx:442` — "slop-deps alpha". Version identity should come from one place. **Owner: AI Studio**

---

## 🟢 LOW

1. **`site/morpho/README.md`** — still AI Studio boilerplate with an app URL. Repo hygiene; delete or replace. (Known kachra — noting for the record.)
2. **Google Fonts runtime dependency** (`index.html:36-41`) — fonts.ready gate handles failure fine, but "files never leave your browser" is slightly undercut by Google getting visitor IPs; self-host the two font files if you want the claim airtight.
3. **Fixed 2400+902 particles, no device-tier scaling** (`SlopDepsCanvas.tsx:17-18`) — DPR cap (1.25/1.5 by cores) helps; for awards-level low-end mobile, scale core count down on small viewports / low `navigator.hardwareConcurrency`.
4. **JSONC comment stripper can silently kill a tsconfig** (`src/index.js:85`) — a string value containing `//` (e.g. a regex-ish alias) truncates the line → `JSON.parse` throws → whole alias set silently ignored. Acceptable, but a debug log in dev would help.
5. **`maskStrings` quadratic concat** (`js-ts.js:90-110`) — `strings[last] += ch` per char; use array + join for giant single-string files. Perf only.
6. **fixer trusts AI's `new` string** (`src/fixer.js:68`) — `lines[idx].replace(fx.old, fx.new)` can inject anything the model returns (BYOK, low risk). Validate `new` matches an import-shaped line before applying.
7. **pypi.js doesn't memoize 404 results in the module CACHE** (`src/registries/pypi.js:45-59` vs npm.js which does) — minor inconsistency, retry cost only.

8. **Dashboard SARIF button re-scans** instead of using `lastFindings` (web/dashboard.html:130-144) — wasteful on big trees; store the sarif payload from the first scan.
9. **`vite.config.ts allowedHosts: true`** — dev-server only; fine, just don't ship a prod server with it.
10. **`web/social-preview.html`** — unclear purpose/dead artifact; confirm or delete.

---

## Verdict & numbers

- **CLI (v1.4.0):** ship-quality for an indie tool. 57/57 tests, honest offline mode, real privacy story, no secrets, solid extractor engine. Fix H3 + H4 before the next release so CI and the GitHub Action actually work.
- **Site:** visually/structurally much improved (accessibility, reduced-motion, skip, state machine all real), **but C1 makes the core demo backfire on real files** — fix C1 + H1 + H2 before showing this to anyone technical, or the site actively damages the tool's credibility.
- Order of attack: **C1 (30 min) → H1 (1-2 h) → H3 (2 min) → H4 (30 min) → H2 (half day) → mediums.**

---

# 🤖 Agent-ready prompts

## Prompt 1 — AI Studio (site fixes)

```
Fix these bugs in the slop-deps website (site/morpho). Work in
this exact order. Do not refactor unrelated code. After all fixes,
run the production build and verify zero TypeScript errors.

1. CRITICAL — fileInspector.ts (src/utils/fileInspector.ts,
function inspectDroppedFileAsync, around line 523): the
isBuiltin() result is computed but never used to gate the registry
check. As a result, `import fs from 'node:fs'` and Python `import
os/sys/json` are checked against npm/PyPI, both 404, and shown as
red HALLUCINATED. Fix: immediately after the builtin check, if
isBuiltin(pkgName, pkgEco) is true, return an InspectedPackage
with verdict 'VERIFIED', isBuiltin: true, registryChecked: true,
reason 'standard library module' — skip typosquat and registry
entirely. Additionally, in checkPackageInRegistry, early-return
'skipped_builtin' if the name starts with 'node:'. Write a
regression check in a comment listing: node:fs, node:path, os,
sys, json must all be VERIFIED.

2. HIGH — same file, lines ~532-543: a typosquat match currently
```

returns SUSPICIOUS without any registry check, but the CLI marks established lookalike packages as VERIFIED with a caution note. Change the flow: when findTyposquatCandidate returns a match, do NOT return early — store the match, proceed to the registry check, and: if registry says not_found → HALLUCINATED (keep the resembles note in reason); if registry says exists → verdict VERIFIED with reason "closely resembles '<target>' — verify this import was intentional" and keep resembles: target. Keep SUSPICIOUS only for crates-ecosystem typosquat matches (no registry check possible there). Reference behavior: src/registries/npm.js in the CLI repo root, lines 106-125.

3. MEDIUM — SlopDropBox.tsx processNativeFiles: reject any dropped file larger than 2,000,000 bytes with a per-file error state "file too large (2 MB max)" instead of scanning it.

4. MEDIUM — fileInspector.ts: the per-file concurrency pool (MAX_CONCURRENT_REQUESTS = 6) stacks across multiple dropped files. Add a module-level global semaphore (a simple counter + FIFO of resolvers, max 6 active) that checkPackageInRegistry must acquire before fetching, so 10 files dropped at once still produce max 6 in-flight requests.

5. MEDIUM — SlopDepsCanvas/TopPixelBar: replace the hardcoded "slop-deps alpha" label with "slop-deps" (no version claim on the site).

6. In index.html, og:image and twitter:image use the relative URL "/og-image.png". Leave a TODO comment to switch both to absolute URLs once the production domain is known (do not invent a domain).

7. Rebuild dist (npm run build) and confirm the string "builtin module not on registry" no longer appears in the emitted bundle.

Definition of done: dropping a package.json containing {"dependencies": {"koa2": "^1.0.0", "express": "^4.0.0"}} shows koa2 as VERIFIED with a "closely resembles" note (not red), express as VERIFIED, and a .py file containing "import os" shows os as VERIFIED (builtin), with zero red rows.

# Prompt 2 — AI Studio (vendor sync, do AFTER Prompt 1 is verified)

Task: eliminate the vendored-scanner drift between the CLI (repo root src/) and the site (site/morpho/src/vendor/slop-deps/).

Current state: the vendor copies are hand-rewritten files with different algorithms and a much smaller corpus (npm 122 entries vs the CLI's 3,056; pypi 85 vs 1,021; crates 69 vs 102) and a stale builtins list (missing sqlite, sea, sidecar_sdk, fs/promises,

etc.). The site and CLI therefore disagree on real inputs.

Build a one-way sync: create site/morpho/scripts/sync-vendor.mjs (pure Node, no deps) that imports from the repo root: src/typosquat.js (CORPUS data + findTyposquatCandidate + isPopularPackage), src/builtins.js (all builtin tables), src/pypi-map.js (PYPI_IMPORT_TO_DIST), src/corpus.generated.js (generated lists) and writes pure-ESM, browser-safe data modules into site/morpho/src/vendor/slop-deps/:
- corpus.generated.js exporting CORPUS = { npm: [...], pypi: [...], crates: [...] } built from curated + generated lists (note the site uses the key 'crates', the CLI uses 'cargo' — map accordingly),
- builtins.js exporting NODE_BUILTINS/PYTHON_BUILTINS sets + isBuiltin(name, ecosystem) handling 'npm' | 'pypi' | 'crates',
- pypi-map.js exporting the full import→dist map + normalizePypiName,
- typosquat.js exporting findTyposquatCandidate/isPopularPackage with the CLI's confusables + digraphs + age-gated severity semantics, with the ecosystem key mapping.

Wire the script into the site package.json as "prebuild". Do not change any component behavior — fileInspector.ts imports should keep working unchanged. Verify: npm run build succeeds and the emitted corpus chunk is visibly larger than the current 2.3 KB one. Add a short note in site/morpho/src/vendor/slop-deps/README.md that these files are GENERATED — never edit by hand.

# Prompt 3 — Antigravity (CLI + CI + action)

Fix these issues in the slop-deps CLI repo. Do not touch site/.

1. .github/workflows/ci.yml lines 4 and 7: `branches: ain]` is corrupted — the workflow never triggers. Change both to `branches: [main]`. Then verify with `act` or by inspecting that the YAML parses and the branch filter references an existing branch.

2. action.yml: the scan step runs with bash -e; when slop-deps exits 1 on critical findings, the step fails and the "Upload SARIF artifact" step (which has no if: always()) never runs — the SARIF is discarded exactly when findings exist. Restructure: run the scan with `set +e`, capture the exit code, upload the artifact with `if: always() && inputs.sarif == 'true'`, then exit with the captured code in a final step. Also pin actions/upload-artifact@v4 to its full commit SHA (this is a supply-chain security tool; tag-pinned actions are not acceptable here).

3. src/server.js (dashboard): add Host header validation — reject any request where req.headers.host is not `127.0.0.1:<port>` or

```
`localhost:<port>` with 403. This closes the DNS-rebinding read
path on /api/scan.

4. src/extractors/js-ts.js: isInsideJsxOrBlock() (lines 199-310)
rescans from offset 0 for every pattern match, and
extractJsImports computes line numbers with masked.slice(0,
match.index+1).split('\n') per match — O(n×m) on minified files.
Optimize: build the full-file prefix arrays once per
extractJsImports call (brace-depth-per-index and line-start
index), pass them into isInsideJsxOrBlock, and use a precomputed
newline index for line numbers. Behavior must be identical — the
existing test suite (node test/run-tests.js) must stay 57/57
green, and add one new test scanning a synthetic 2 MB minified
file with 5,000 require() calls that completes in under a few
seconds.

5. src/fixer.js applyFixes(): before applying, validate that
fx.new looks like the same import statement with only the
specifier changed (same quote style, contains no ';' and no
newline, and the line still contains the original binding prefix).
Skip with reason 'suspicious suggestion' otherwise.

6. Housekeeping: delete web/social-preview.html only after
confirming it is unused (grep the repo and README for references;
if referenced, update the references instead).

Definition of done: npm test passes 57/57 (or 58 with the new perf
test), the workflow YAML is valid and targets main, and node bin/
slop-deps.js --dir demo still exits 1 with 5 criticals.
```

---

Audit artifacts: reproduction scripts at scripts/test-site-scanner.mjs, scripts/test-site-scanner-real.mjs, scripts/test-divergence.mjs (run with tsx). All three can be re-run after fixes to verify the bugs are gone.